❶ The return URL is provided as an argument to the action method.

❷ Returns true if the return URL starts with / or ~/

❸ The URL is local, so it's safe to redirect to it.

❹ The URL was not local and could be an open redirect attack, so redirect to the homepage for safety.

This simple pattern protects against open redirect attacks that could otherwise expose your users to malicious content. Whenever you're redirecting to a URL that comes from a query string or other user input, you should use this pattern.

TIP In some authentication flows, such as when authenticating with OpenID Connect, you *can't* redirect to a local URL, so you can't use this pattern. Instead, OpenID Connect requires that you preregister the allowed redirect URLs and redirect only to a registered URL. You should consider using this pattern when you can't enforce a local-only redirect.

Open redirect attacks present a risk to your *users* rather than to your app directly. The next vulnerability represents a critical vulnerability in your app itself.

29.4.2 Avoiding SQL injection attacks with EF Core and parameterization

SQL injection attacks represent one of the most dangerous threats to your application. Attackers craft simple malicious input, which they send to your application as traditional form-based input or by customizing URLs and query strings to execute arbitrary code against your database. An SQL injection vulnerability could expose your entire database to attackers, so it's critical that you spot and remove any such vulnerabilities in your apps.

I hope I've scared you a little with that introduction, so now for the good news: if you're using Entity Framework Core (EF Core) or pretty much any